

# SQLIQ

## AI-assisted Azure SQL governance

IT & BOARD BRIEFING | PUBLIC REFERENCE | 6 OCTOBER 2026

### Decision sought

Sponsor a governed evaluation of AI-assisted SQL review. Authorize an offline pilot using synthetic evidence first. Production access and AI data disclosure require separate organizational approval and verified deployment controls.

### Assurance status: NOT ASSESSED

No company, tenant or database has been assessed by this briefing. No live connection was made. This is a proposal and responsibility guide, not an audit opinion, legal determination or certification. All organization-specific evidence remains outstanding.

### Where AI adds value

Codex and Claude can coordinate Azure, SQL and compliance review through pinned AEF workflows: explain evidence, propose migration and schema plans, analyze supplied performance plans, draft control mappings and prioritize remediation. Each conclusion needs traceable evidence and human review. The graph runtime itself is deterministic; it does not call a model. AI assistance comes from the authorized agent host.

### Authority stays with people

Live reads default to disabled and require an exact, fresh, externally signed approval. The read broker permits bounded catalog metadata reads. Writes need separate exact signed approval. Only nullable-column additions are supported. AI cannot sign, grant itself access or promote learned candidates. Deployment isolation must be independently demonstrated.

### Board oversight

Assign an accountable executive, IT control owner and independent reviewer. Require evidence of data handling, identity separation, reproducible findings and recovery readiness before expanding scope. Risk acceptance needs a named owner and expiry.

## 01 / Azure and customer responsibility

Baseline: Azure SQL Database PaaS in the public cloud. Provider responsibility is a candidate for inherited assurance, never an automatic PASS. Match provider attestations to service, region, period, exclusions and customer obligations. Managed Instance and SQL Server on VMs require separate scope reviews. [1-3]

| Control area                              | Responsibility                           | Evidence / accountable owner                                                                             |
|-------------------------------------------|------------------------------------------|----------------------------------------------------------------------------------------------------------|
| Physical facilities, hosts and hypervisor | Provider                                 | Obtain current provider assurance covering the service, region and review period. [1,3]                  |
| Managed OS and SQL service maintenance    | Provider for SQL Database PaaS           | Verify service scope and maintenance commitments. SQL Server on a VM has different duties. [1,2]         |
| Data, classification, accounts and access | Customer                                 | IT/security: approve least privilege, access reviews, segregation of duties and data retention. [1]      |
| Network and application protections       | Shared                                   | IT: demonstrate private connectivity, application security, approved identities and egress. [1,2]        |
| Encryption, keys and TLS                  | Shared implementation                    | Security: verify configured encryption, key custody, clients and full applicable TLS requirements. [2,4] |
| Audit, detection and incident response    | Shared implementation                    | Security: configure exports, retention, alert ownership and incident exercises. [2]                      |
| Recovery and financial integrity          | Customer outcomes; provider capabilities | DBA/finance: approve recovery objectives; test restores and ledger reconciliation. [2]                   |
| Compliance scope and exceptions           | Customer                                 | Compliance: approve applicability, evidence, exceptions and independent review. [3,5]                    |

Inheritance evidence: control ID, provider report reference, coverage dates, service scope, customer complementary controls, reviewer and residual gap. Keep restricted provider reports outside the public repository.

## 02 / AI adoption with explicit controls

### Data exposure and confidentiality

Start with synthetic or approved redacted inputs. Schema names, plans and error messages can be sensitive even without business rows. The host can transmit supplied context to its model provider. Local report generation does not establish that Codex or Claude is offline. IT must verify provider contracts, retention, training terms, residency and approved classifications before enabling a host.

### Accuracy and hostile input

Treat retrieved documents, skills and database metadata as untrusted evidence. Require source references and reproducible checks. Unsupported claims remain NOT\_ASSESSED. Review model conclusions independently; prompts are not enforcement.

### Credentials and separation of duties

Keep reviewer keys and broker credentials outside agent reach. Demonstrate effective read-only permissions, separate identities, immutable audit export, network restrictions and tamper-resistant deployment. These production controls are requirements, not verified features of a customer installation.

### Token efficiency

Use code for parsing, rule inventory, hashing, validation and PDF rendering. Send only approved, minimal evidence excerpts to AI for interpretation. Reuse reviewed summaries keyed to source hashes; invalidate them on change. Set per-task token budgets and escalate reasoning only for ambiguity or high-impact changes. Never trim control coverage or approval checks to save tokens.

### Learning and supply chain

Pin and review imported skills. Learning uses de-identified enumerated outcomes and creates review candidates only. No model retraining, automatic policy change or unrestricted memory ingestion. Require tests and release review.

### Adoption decision gates

Phase 1: policy-approved synthetic offline evaluation. Phase 2: approved host and classified evidence review. Phase 3: isolated broker with independently verified controls and signed reads. Record owner, evidence and decision at each gate. If organizational policy prohibits AI, obtain a policy exception or use the deterministic CLI without an AI host; never route around the restriction.

## 03 / Evidence and assurance plan

### SQL STIG and TLS

Select the exact official product benchmark and release. Inventory every rule and record applicability, responsibility, evidence, result and reviewer. Provider-managed rules still require an inheritance rationale. Review NIST SP 800-52 TLS requirements separately; a minimum TLS setting alone is insufficient. [4,5]

### Finance applicability

Compliance and counsel determine applicable obligations and versions, including SOX, GLBA or PCI DSS where relevant. Finance validates segregation of duties, change approvals, retention and reconciliations. Azure attestations do not establish the company's compliance. No universal finance SQL checklist applies. [3]

### Evidence needed before production

IT: effective grants, network and key controls, restore exercises and audit retention. Security: host data handling, threat review, approval identity, replay and isolation tests. Compliance: benchmark scope, provider assurance mapping and time-limited exceptions. Board: accountable owner and accepted residual risks. Status for all customer evidence: NOT ASSESSED.

### Report interpretation

The STIG HTML command inventories every supplied XCCDF rule and displays optional operator findings. It does not run a full database scan or independently verify assertions. Missing findings remain NOT\_ASSESSED. This PDF is a generic governance briefing; it contains no customer-specific findings.

### Primary sources | verify currency at review time

[1] Microsoft shared responsibility  
<https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility>

[2] Azure SQL security overview  
<https://learn.microsoft.com/en-us/azure/azure-sql/database/security-overview>

[3] Microsoft compliance offerings  
<https://learn.microsoft.com/en-us/azure/compliance/offerings/>

[4] NIST SP 800-52 Rev. 2  
<https://csrc.nist.gov/pubs/sp/800/52/r2/final>

[5] DISA STIG distribution  
<https://public.cyber.mil/stigs/downloads/>